

Encuesta Integral sobre Adopción, Madurez e Indicadores SASE

Borrador de modelo de encuesta para responsables de ciberseguridad, redes, continuidad de negocio y riesgo empresarial. Diseñada para evaluar el grado de adopción, madurez y valor de una arquitectura SASE/Zero Trust y su alineamiento con ENS, NIS2 y marcos internacionales.

1. Datos generales de la organización

G1. Tipo de organización

Marque la opción que mejor describa su organización:

- Administración pública estatal.
- Administración autonómica.
- Administración local / entidad supramunicipal.
- Empresa privada – gran empresa (≥ 250 empleados).
- Empresa privada – pyme (< 250 empleados).
- Operador de servicios esenciales / infraestructuras críticas.
- Otro (especifique brevemente).

G2. Sector principal de actividad

- Administración general / servicios transversales.
- Sanidad y servicios sociosanitarios.
- Educación y universidades.
- Justicia y seguridad pública.
- Finanzas, seguros y servicios profesionales.
- Industria, energía y utilities.
- Telecomunicaciones y servicios digitales.
- Otros (logística, turismo, etc.).

G3. Ámbito geográfico predominante de operación

- Local / regional.
- Nacional (principalmente España).
- Europeo.
- Global (operaciones significativas fuera de la UE).

G4. Tamaño aproximado de la plantilla

- Menos de 250 personas.
- Entre 250 y 2.500 personas.
- Entre 2.501 y 10.000 personas.
- Más de 10.000 personas.

G5. Número aproximado de usuarios remotos o híbridos habituales (teletrabajo $\geq$ 2 días/semana)

- Menos de 100 usuarios.
- De 100 a 1.000 usuarios.
- De 1.001 a 5.000 usuarios.
- Más de 5.000 usuarios.

2. Situación actual de arquitectura de red y seguridad

A1. Modelo predominante de acceso a recursos internos

¿A través de qué mecanismos acceden habitualmente los usuarios remotos a aplicaciones internas críticas?

- VPN tradicional con acceso de red amplio (lo que viene siendo “entra y ya veremos a qué no deberías llegar”).
- VPN segmentada con reglas específicas por grupo o aplicación.
- ZTNA (Zero Trust Network Access) para algunos colectivos o aplicaciones concretas.
- ZTNA como mecanismo principal para todo acceso remoto a aplicaciones internas.
- Mixto en transición: la VPN tiene fecha de jubilación, aunque todavía no se ha comprado la tarta.

A2. Uso actual de una plataforma SASE/SSE

¿Cuál describe mejor su situación respecto a SASE/SSE?

- No utilizamos ninguna solución identificable como SASE/SSE.
- Utilizamos componentes dispersos (SD-WAN, SWG, CASB, ZTNA...), pero sin una plataforma unificada.
- Hemos desplegado una plataforma SSE (SWG, CASB, ZTNA, FWaaS) sin SD-WAN integrado.
- Utilizamos una plataforma SASE unificada (SD-WAN + SSE) con un único plano de gestión.
- Utilizamos varias plataformas SASE/SSE de distintos fabricantes (ecosistema “coleccionista de consolas”).

A3. Alcance de la arquitectura SASE/SSE sobre el tráfico hacia la nube

¿Qué porcentaje aproximado de su tráfico hacia aplicaciones SaaS y servicios cloud pasa hoy por su plataforma SASE/SSE?

- 0–25 % (cada proyecto cloud se defiende como puede, a veces con amuletos).
- 26–50 % (estamos a mitad de camino: parte del tráfico ya pasa por SASE).
- 51–75 % (la mayor parte del tráfico cloud sigue un camino razonablemente seguro).
- 76–100 % (hemos asumido que el perímetro ahora nos persigue a nosotros y lo hemos abrazado).

A4. Cobertura SASE/SSE sobre sedes físicas

- Ninguna sede está conectada mediante SD-WAN/SASE.
- Solo sedes principales (HQ, CPD, oficinas grandes) usan SD-WAN/SASE.
- La mayoría de sedes relevantes usan SD-WAN/SASE.
- Todas (o casi todas) las sedes están integradas en SD-WAN/SASE.

3. Identidad, autenticación y enfoque Zero Trust

B1. Autenticación multifactor (MFA) en usuarios con acceso a datos sensibles

¿Qué porcentaje aproximado de estos usuarios cuenta con MFA activo?

- 0–25 % (la contraseña sigue siendo la llave maestra, y todos rezan).
- 26–50 % (MFA en ámbitos donde “ardía” más).
- 51–75 % (MFA por defecto para perfiles críticos, excepciones vigiladas).
- 76–100 % (la confianza se negocia en cada inicio de sesión, sin excepción).

B2. Uso de políticas contextuales de acceso (ubicación, dispositivo, riesgo)

- No utilizamos políticas contextuales; el mundo es plano y el acceso también.
- Se aplican algunas políticas contextuales sencillas (por país, por rango IP).
- Políticas contextuales moderadas (ubicación, tipo de dispositivo, horario).
- Políticas avanzadas basadas en riesgo (estado de dispositivo, comportamiento, reputación, etc.).

B3. Segmentación de acceso a aplicaciones internas

¿Cómo describiría su modelo actual?

- Red prácticamente plana, con VLANs heroicas y algo de fe.
- Segmentación básica por zonas (oficinas, CPD, proveedores, invitados).
- Segmentación granular basada en identidad y rol (principio de mínimo privilegio aplicado en serio).
- Segmentación dinámica basada en riesgo y clasificación de datos.

B4. Cobertura de ZTNA sobre aplicaciones internas

- 0–25 % de las aplicaciones internas críticas están expuestas solo a través de ZTNA.
- 26–50 %.
- 51–75 %.
- 76–100 % (el acceso a red “bruto” ya es un recuerdo o una pesadilla recurrente).

B5. Formalización de un roadmap Zero Trust

- No existe un roadmap Zero Trust formal.
- Existe un documento inicial, pero no está alineado con negocio ni presupuesto.
- Existe un roadmap aprobado y alineado con TI y seguridad.
- Existe un roadmap Zero Trust aprobado a nivel de dirección, con hitos y métricas.

4. Métricas de rendimiento, QoS y QoE en SASE

C1. Medición de latencia y rendimiento hacia aplicaciones SaaS clave

- No medimos de forma sistemática la latencia hacia aplicaciones SaaS.
- Medimos latencia y pérdida de paquetes desde la red, pero sin vista de usuario final.
- Disponemos de métricas de experiencia digital (DEM/RUM) integradas con SASE para algunas aplicaciones.
- DEM/RUM integrado de forma amplia, con paneles de experiencia por aplicación, grupo de usuarios y ubicación.

C2. Umbrales objetivos (SLOs) de experiencia de usuario

- No tenemos SLOs definidos; mientras “no se caiga”, damos gracias.
- Tenemos algunos SLOs de red (latencia, disponibilidad) sin traducir a experiencia.
- Tenemos SLOs de QoE para aplicaciones clave, revisados ocasionalmente.
- Tenemos SLOs de QoE formalizados, revisados con negocio y usados para priorizar inversiones.

C3. Impacto percibido de SASE en la experiencia de usuario

¿Cómo describiría la percepción dominante de los usuarios respecto a SASE?

- Lo perciben como un obstáculo (más lento, más pasos, más frustración).
- Lo perciben como neutro (no se quejan más que antes, lo cual ya es un logro).
- Lo perciben como una mejora (acceso más fluido y homogéneo, menos problemas).
- Han olvidado que existe: “simplemente funciona”, que es el mayor cumplido posible.

C4. Visibilidad de la experiencia por tipo de tráfico (voz, vídeo, transaccional)

- No diferenciamos por tipo de tráfico.
- Contamos con algunas métricas para voz o vídeo.
- Tenemos paneles de QoE por categoría de tráfico (voz, vídeo, SaaS, tráfico interno).
- Disponemos de paneles de QoE y usamos esos datos para ajustar políticas de ruteo y seguridad.

5. Métricas de seguridad, detección y respuesta en SASE

D1. Integración de la telemetría SASE con el SIEM/SOC

- La telemetría SASE vive en su propio portal, como un reino independiente.
- Enviamos algunos logs críticos (incidentes mayores, alertas de alto nivel) al SIEM.
- Integramos de forma amplia eventos de SWG, CASB, ZTNA, FWaaS en el SIEM.
- Usamos la telemetría SASE como fuente principal para casos de uso de threat hunting y análisis forense.

D2. Métricas específicas de detección y respuesta en SASE (MTTD, MTTR, MTTC)

- No medimos estos tiempos de forma diferenciada para el plano SASE.
- Los medimos de forma genérica, sin distinguir el origen.
- Medimos MTTD/MTTR/MTTC específicos para incidentes SASE.
- Además, tenemos objetivos (SLOs) y revisiones periódicas en comités de seguridad.

D3. Bloqueo de amenazas a través de SASE

¿Qué nivel de visibilidad y métricas tiene sobre amenazas bloqueadas por el plano SASE?

- Conocemos el número total de eventos, sin mucho detalle.
- Tenemos estadísticas por tipo de amenaza (malware, phishing, C2, exfiltración).
- Tenemos métricas por tipo de amenaza y por colectivo/ubicación/aplicación.
- Además, correlacionamos estas métricas con campañas, ejercicios de Red Team y cambios de política.

D4. Ratio de falsos positivos y su impacto operativo

- No medimos formalmente el ratio de falsos positivos.
- Lo medimos de forma puntual cuando “arde” producción.
- Tenemos un seguimiento periódico y lo usamos para ajustar políticas.
- Los ratios de falsos positivos forman parte de los objetivos de calidad del servicio de seguridad.

D5. Evaluación del impacto de controles avanzados (TLS inspection, DLP, sandbox)

- No evaluamos su impacto; si funciona y no se quejan mucho, seguimos.
- Evaluamos el impacto subjetivamente, en base a feedback de usuarios clave.
- Medimos de forma cuantitativa el impacto en latencia/QoE de estos controles.
- Contamos con un proceso formal para equilibrar riesgo y experiencia, con experimentos controlados (A/B, pilotos).

6. Cumplimiento ENS, NIS2 y otros marcos

E1. Uso de SASE para implantar medidas ENS en servicios cloud

- Residual: cada proyecto cloud define sus propios controles.
- Parcial: algunas medidas ENS (control de acceso, registro) se centralizan en SASE.
- Amplio: SASE es el plano común de control y visibilidad para la mayoría de servicios cloud.
- Casi total: los proyectos cloud están obligados a integrarse con SASE como requisito de diseño.

E2. Grado de alineamiento entre diseño SASE y ENS/NIS2

- No existe un mapeo explícito entre SASE y ENS/NIS2.
- Existe un mapeo parcial, elaborado por seguridad.
- Existe un mapeo formal revisado por seguridad y cumplimiento.
- SASE forma parte de la estrategia oficial para dar cumplimiento a ENS y NIS2, con trazabilidad documentada.

E3. Gestión de terceros y proveedores de servicios SASE/SD-WAN/SSE

- No tenemos requisitos específicos de SASE en contratos con proveedores.
- Incluimos algunas cláusulas de seguridad y disponibilidad básicas.
- Exigimos certificaciones (ENS, ISO 27001, NIS2-ready, etc.) y reportes de ciberseguridad periódicos.
- Además, exigimos integración de telemetría, ejercicios conjuntos y pruebas de resiliencia.

E4. Auditorías, simulacros y pruebas de eficacia

- SASE apenas aparece en auditorías y simulacros.
- SASE se revisa en algunas auditorías técnicas.
- SASE es objeto recurrente de auditorías, pruebas de penetración y simulacros de continuidad.
- Existe un programa estructurado de pruebas de eficacia de controles SASE, con seguimiento de hallazgos y remediación.

7. Adopción, madurez SASE y consolidación de plataformas

F1. Nivel de madurez SASE percibido

- Fase exploratoria: pilotos, POC y debates apasionados, pero poco despliegue en producción.
- Fase táctica: soluciones desplegadas para casos de uso concretos (teletrabajo, algunas sedes).
- Fase estratégica: SASE está integrado en la estrategia de infraestructura y seguridad.
- Fase optimizada: SASE se gestiona como plataforma troncal, con métricas y mejora continua.

F2. Consolidación de herramientas de red y seguridad

- Apenas se ha consolidado nada; cada nueva herramienta vino “a sumar, nunca a sustituir”.
- Se han sustituido algunas soluciones puntuales (por ejemplo, VPN heredada).
- Se ha consolidado de forma notable (reducción de proveedores, productos y contratos).
- La consolidación está alineada con una estrategia explícita de simplificación y ahorro.

F3. Gobernanza conjunta redes–seguridad–riesgos sobre SASE

- SASE se gestiona principalmente desde redes.
- SASE se gestiona principalmente desde seguridad.
- Existe un comité o foro conjunto redes–seguridad que decide sobre SASE.
- Además, riesgos/compliance participa en las decisiones clave de SASE.

F4. Percepción de valor de SASE por la alta dirección

- Lo perciben como “otro gasto de TI” para mantener las luces encendidas.
- Lo perciben como una mejora necesaria de seguridad y cumplimiento.
- Lo perciben como facilitador de negocio (trabajo híbrido, agilidad, nuevas iniciativas digitales).
- Lo perciben como parte estratégica de la resiliencia y continuidad del negocio.

8. Continuidad de negocio y resiliencia apoyadas en SASE

G1. Uso de SASE para continuidad de negocio

- No se ha considerado explícitamente SASE en los planes de continuidad.
- Se menciona SASE tangencialmente en algunos planes.
- SASE forma parte de los escenarios y medidas de continuidad (fallo de sedes, PoPs, proveedores, etc.).
- Se realizan simulacros en los que se evalúa explícitamente la resiliencia de la arquitectura SASE.

G2. Redundancia y diseño de alta disponibilidad

- Enlaces simples y sin plan de contingencia específico.
- Algunos enlaces redundantes y/o PoPs alternativos.
- Redundancia sistemática en sedes críticas y servicios clave.
- Diseño multi-PoP y multi-operador con pruebas periódicas de conmutación.

G3. Visión integrada de riesgo tecnológico y operativo

- El riesgo de fallos SASE no está modelizado.
- Se considera de forma cualitativa en algunos análisis de riesgo.
- Está modelizado cuantitativamente en el mapa de riesgos de TI.
- Existe modelización cuantitativa y escenarios de impacto económico (pérdida de servicio, productividad, etc.).

9. Indicadores de negocio, IGM y ROI asociados a SASE

H1. Existencia de un Índice Global de Madurez (IGM) de ciberseguridad o SASE

- No disponemos de un índice de madurez formal.
- Disponemos de un índice general de madurez de ciberseguridad (no específico de SASE).
- Disponemos de un índice de madurez SASE / Zero Trust, aunque aún está en revisión.
- El IGM SASE/Zero Trust está definido, comunicado y ligado a objetivos de mejora.

H2. Uso de métricas financieras para evaluar SASE (ROI, TCO, coste evitado)

- No utilizamos métricas financieras específicas para SASE.
- Hemos estimado un TCO básico (licencias, proyectos), sin analizar beneficios.
- Hemos desarrollado algún cálculo de ROI (ahorro, coste evitado, productividad).
- Contamos con un modelo de ROI recurrente que se revisa anualmente y se presenta a la dirección.

H3. Beneficios más relevantes percibidos de SASE

(Seleccione hasta tres opciones)

- Mejora de la postura de seguridad (menos incidentes, menor exposición).
- Mejora del cumplimiento regulatorio (ENS, NIS2, GDPR, etc.).
- Mejora de la experiencia de usuario y productividad.
- Simplificación y consolidación de herramientas.
- Reducción de costes operativos.
- Mejora de visibilidad sobre datos y aplicaciones cloud.
- Otros (especifique).

H4. Principales obstáculos para maximizar el valor de SASE

(Seleccione hasta tres opciones)

- Complejidad técnica y de integración.
- Resistencia cultural y organizativa.
- Limitaciones presupuestarias.
- Falta de métricas claras de éxito.
- Dependencia excesiva de proveedores.
- Escasez de perfiles especializados.
- Otros (especifique).

10. Preguntas abiertas (opcional pero muy revelador)

01. Si tuviera que describir en una frase qué ha cambiado SASE en su organización, ¿qué diría?

Respuesta abierta.

02. ¿Cuál ha sido la lección más dura aprendida en su viaje hacia SASE/Zero Trust?

Respuesta abierta.

****03. Si pudiera “borrar” una decisión tomada en su proyecto SASE, ¿cuál sería y por qué?**

_Respuesta abierta.

04. ¿Qué métrica o indicador le gustaría ver cada mañana en su panel de SASE para saber que todo va razonablemente bien?

Respuesta abierta.

05. ¿Hay algún aspecto de SASE que considere especialmente útil para su contexto nacional (ENS, NIS2, sector, etc.) y que no suela aparecer en los folletos de marketing?

Respuesta abierta.